

G-CAF

GovDigital Composable Architecture Framework

Volume 11

Agent & AI Security Governance

v2.1

Table of Contents

PART A — AGENT EXTENSION (v1.4+)

Chapter 1 Agent PBC Type

Definition, characteristics, and comparison with other PBC types

Chapter 2 Agent Maturity Model (L0–L4)

From rule-based chatbots to agent-of-agents

Chapter 3 Agent Orchestration Patterns

6 patterns: Single, Sequential, Parallel, Supervisor, Group Chat, Hierarchical

Chapter 4 Agent Integration Layer

Agent Registry, Agent Bus (A2A), Tool Registry (MCP), Memory Store

Chapter 5 Agent Gateway Extensions

Additional gateway checklist items for Agent PBCs

Chapter 6 8 Agent Governance Contracts

Identity, Autonomy, Guardrails, Memory, Interoperability, Oversight, Observability, Security

PART B — AI SECURITY EXTENSION (v2.1)

Chapter 7 AI Security Maturity (L1–L5)

From foundational IT security to adaptive AI security operations

Chapter 8 Context-Specific AI Security Guidance

Risk tiers, safety-critical requirements, fairness-sensitive systems

Chapter 9 Adversarial Threat Intelligence

MITRE ATLAS, NIST AI RMF, threat taxonomy requirements

Chapter 10 9 AI Security Contracts

Master, Algorithm, Adversarial Defense, Inference, Privacy-Preserving ML, Observability, Training Data, Incident Response, Forensics

Chapter 1

Agent PBC Type

The Agent PBC is the sixth PBC type within G-CAF, enabling governance of autonomous AI capabilities that reason, plan, take actions, and collaborate.

Attribute	Specification
Primary Function	Autonomous AI: perceive context, reason about goals, plan actions, execute, learn
Data Relationship	Consumes context (tools, memory); produces actions, decisions, artifacts
Distinguishing Feature	Has identity, invokes tools autonomously, supports orchestration, requires guardrails
Autonomy Spectrum	Human-supervised (L0) to fully autonomous (L4) within defined boundaries

Agent PBC vs. Other Types

PBC Type	Key Distinction from Agent PBC
Application PBC	Manages entity lifecycle (CRUD); Agent manages autonomous decision-making
Analytics PBC	Produces insights for human consumption; Agent acts on insights autonomously
Data PBC	Provides lookups and reference data; Agent consumes data for autonomous decisions
Orchestration PBC	Coordinates via static/rule-based logic; Agent uses AI reasoning for dynamic routing
Digital Twin PBC	Represents physical assets; Agent may interact with twins but focuses on reasoning

Agent PBC Anatomy

Interface Contract (Agent Card, MCP/A2A protocols, I/O schemas) → Agent Core (Reasoning Engine, Planner, Tool Invoker, Memory Manager) → Guardrails Layer (input validation, output screening, behavioral boundaries, escalation triggers) → Tool Access (via MCP through API Gateway).

Chapter 2

Agent Maturity Model (L0–L4)

Level	Name	Autonomy	Human Role	Examples
L0	Rule-Based / Chatbot	None	Full control	FAQ bots, IVR, form wizards
L1	Retrieval + Recommendation	Minimal	Approves all actions	Search assistants, suggestion engines
L2	Simple Autonomous	Moderate	Approves significant actions	Document classifier, task executor
L3	Multi-Agent Orchestration	High	Exception-based oversight	Supervisor + specialist agents
L4	Agent-of-Agents	Very High	Strategic oversight only	Meta-orchestration, self-improving

Each level has specific requirements for reasoning, actions, learning, governance, memory, and the gateway checks that must be satisfied.

Chapter 3

Agent Orchestration Patterns

Pattern	Complexity	Use Case	Governance Overhead
Single Agent	Low	Bounded tasks; clear scope	Standard
Sequential	Low-Medium	Multi-stage pipelines	Standard
Parallel	Medium	Ensemble reasoning; parallel data gathering	Elevated (token cost)
Supervisor	Medium-High	Dynamic task routing; specialist coordination	Elevated
Group Chat	High	Collaborative problem-solving	High
Hierarchical	High	Large-scale, multi-domain orchestration	High

Each pattern defines: reasoning loop, tool access model, governance requirements, observability needs, and when to escalate to a higher pattern.

Chapter 4

Agent Integration Layer

Extends Platform Tier (Integration) with agent-specific components alongside existing Service Integration (GovDX) and Data Integration (Data Fabric).

Component	Function	Protocol/Standard
Agent Registry	Agent capability discovery and advertisement	IIA Agent Cards
Agent Bus	Agent-to-agent communication and task routing	IIA Protocol (HTTP/JSON)
Tool Registry	Tool definitions for agent consumption	MCP (Model Context Protocol)
Agent Memory Store	Persistent memory services (short + long-term)	Custom / Vector DB
Agent Observability	Real-time monitoring, audit, and lineage	OpenTelemetry + Custom
Guardrail Services	Centralized guardrail enforcement	Custom

Chapter 5

Agent Gateway Extensions

Agent PBCs require additional gateway checklist items beyond standard G-CAF gateways.

Initiation Gateway (10 additional items)

#	Item	Evidence Required
A1	Agent Justification — why Agent PBC vs. other types	Business case
A2	Maturity Level Target (L0–L4)	Maturity assessment
A3	Autonomy Tier Proposal (T1–T4) with justification	Risk assessment
A4	Orchestration Pattern proposed	Architecture sketch
A5	Guardian Agent Need assessment	Compliance assessment
A6	Human Oversight Model	Operating model document
A7	Tool Access Scope (initial tool list)	Scope document
A8	Data Access Scope	Data access request
A9	Regulatory Considerations	Compliance checklist
A10	AI-Specific Risk Assessment	Risk register entry

Design Gateway adds ~15 items (architecture review, guardrail design, memory design, interop protocol selection). Go-Live adds ~15 items (security validation, guardrail testing, observability confirmation). Retirement adds ~10 items (memory archival, agent deregistration).

ARB Escalation Triggers

Agent PBCs are automatically escalated to ARB if: maturity level L3+, autonomy tier T3+, citizen-facing deployment, or cross-domain agent access.

Chapter 6

8 Agent Governance Contracts

The Agent Governance Contract is a master contract composed of 8 modular sub-contracts, each with its own change driver for bounded maintenance.

Contract	Owner	Key Requirements
1. Identity	Cyber Security	Unique agent ID, Agent Card (A2A), OAuth 2.0/OIDC credentials, semantic versioning
2. Autonomy	EA Office	4 autonomy tiers (T1–T4), action scope whitelists, escalation rules, override controls
3. Guardrails	Cyber Security	Input validation (PII detection, injection detection), output screening, behavioral monitoring, control
4. Memory	Data Office	Short-term (session, working, scratchpad) and long-term (episodic, semantic, procedural) memory
5. Interoperability	Integration Team	MCP for tools (L2+), A2A for agent collaboration (L3+), OpenTelemetry for observability (L2+)
6. Oversight	EA Office	Human-in-the-loop configs (Full Approval, Significant Actions, Exception-Based, Post-Hoc); override
7. Observability	Platform Team	Action logs (1yr), decision logs (1yr), error logs (2yr), audit logs (7yr); distributed tracing across
8. Security	Cyber Security	Threat model (prompt injection, identity spoofing, data exfiltration, DoS, memory poisoning); O

Contract applicability: Master contract mandatory for L2+. All sub-contracts progressively required as maturity level increases.

Chapter 7

AI Security Maturity (L1–L5)

Unlike agent maturity (which measures autonomy progression), AI security maturity measures the organization's AI security posture across all AI system types.

Level	Name	Posture	Key Capabilities
L1	Foundational	Reactive	Standard IT security applied to AI; assets inventoried; no AI-specific policies
L2	Managed	Proactive (basic)	AI risks identified; AIBOM maintained; basic model monitoring; training data access controls
L3	Defined	Systematic	Formal AI security processes; adversarial testing; drift/bias monitoring; privacy evaluation
L4	Quantitative	Predictive	Metrics-driven AI security; automated detection/response; AI forensic capability
L5	Optimizing	Adaptive	Continuous improvement; threat intelligence; privacy-preserving ML at scale; red-teaming

Chapter 8

Context-Specific AI Security Guidance

AI Risk Tiers

Tier	Description	Examples	Min. Ma
Critical	Failure could cause loss of life or critical infrastructure disruption	Medical diagnosis, autonomous vehicle control, power grid	
High	Significant impact on rights, livelihood, or financial standing	Credit scoring, hiring AI, criminal justice, insurance pricing	
Moderate	Operational impact, limited direct harm	Customer service, content recommendation, fraud detection	
Low	Minimal impact on individuals or organizations	Spam filtering, social media analytics, spell-check, image tagging	

Safety-Critical AI Requirements

Requirement	Description
Formal safety case	AI-specific failure modes documented with acceptable residual risk
Redundant AI pathways	Independent model architectures; single-model failure must not cause safety incidents
Deterministic fallback	Safe default mode when AI confidence below threshold
Real-time health monitoring	Automatic failover on degraded model performance
Adversarial robustness certification	Higher robustness guarantees for safety-critical models
Explainability mechanism	All safety-affecting decisions must be explainable
Mandatory human-in-the-loop	Final authority for irreversible decisions remains with qualified human

Chapter 9

Adversarial Threat Intelligence

MITRE ATLAS (Primary Taxonomy)

ATLAS Category	Description	Example Techniques
Reconnaissance	Gathering info about target ML system	Discover ML model family, discover ML artifacts
Resource Development	Establishing resources for ML attacks	Acquire public ML models, develop adversarial inputs
ML Attack Staging	Preparing ML-specific attack components	Craft adversarial data, backdoor ML model, poison training data
Execution	Running adversarial ML techniques	Adversarial ML attack, prompt injection (direct + indirect)
Persistence	Maintaining presence in ML systems	Backdoor in ML model, poison training pipeline
Evasion	Avoiding ML-based detection	Evade ML model, adversarial perturbation, concept drift exploitation
Impact	Manipulating ML outputs	Denial of ML service, model output manipulation, IP theft
Exfiltration	Extracting models or training data	Model extraction, training data extraction, model inversion

Organizations at L3+ must map AI assets against relevant ATLAS techniques. L4+ must feed threat intelligence into adversarial testing and red-team exercises.

9 AI Security Contracts

Contract Applicability by Maturity

Contract	L1	L2	L3	L4	L5
Master Security	—	Req	Req	Req	Req
Algorithm Security	—	Partial	Req	Req	Req
Adversarial Defense	—	—	Req	Req	Req
Inference Security	—	Partial	Req	Req	Req
Privacy-Preserving ML	—	—	Opt	Req	Req
AI Observability	—	Partial	Req	Req	Req
Training Data	—	Req	Req	Req	Req
Incident Response	—	Partial	Req	Req	Req
Forensics	—	—	Opt	Req	Req

Contract Details

Contract	Owner	Key Focus
1. Master Security (AIS-000)	IS-Cyber Security	Overarching principles; AI lifecycle security requirements; scope covering all AI types
2. Algorithm Security (AIS-001)	Security Architecture	Threat modeling (STRIDE+ATLAS); secure training pipelines; model integrity verification
3. Adversarial Defense (AIS-002)	Cyber Security	7 approved defense techniques; input validation; prompt injection detection (direct + indirect)
4. Inference Security (AIS-003)	Security Architecture	API security; rate limiting; output confidentiality; model extraction/inversion defenses
5. Privacy-Preserving ML (AIS-004)	Privacy Office	Differential privacy (epsilon budgets); federated learning; homomorphic encryption; secure aggregation
6. AI Observability (AIS-005)	Performance Team	Behavioral baselines; data drift detection; bias/fairness monitoring; statistical deviation alerts
7. Training Data (AIS-100)	Data Governance	Access control; integrity/poisoning detection; lineage tracking; RLHF validation
8. Incident Response (AIS-107)	IS-Cyber	7 AI incident categories; severity matrix; escalation SLAs; UAE CSC reporting
9. Forensics (AIS-108)	SOC	Model state preservation; inference record chain of custody; training data snapshots; evidence handling

AI Incident Taxonomy (from AIS-107)

Category	Description	Examples
AI-INC-01 Model Failure	Incorrect/degraded outputs beyond expected accuracy levels	Systemic hallucination, hallucination
AI-INC-02 Adversarial Attacks	Deliberate manipulation of inputs, data, or prompts	Evasion, poisoning, model extraction, prompt injection
AI-INC-03 Bias Incidents	Discriminatory outcomes affecting protected groups	Demographic disparity, proxy discrimination
AI-INC-04 Data Drift	Production data diverges from training data	Feature drift, concept drift, seasonal shift
AI-INC-05 Privacy Breach	Leaks training data, PII, or model information	Membership inference, model inversion, memorization
AI-INC-06 Supply Chain	Compromised pre-trained model, data, or infrastructure	Backdoor, model hijack, poisoned dataset, malicious dependency
AI-INC-07 Autonomous Agent Failure	Unauthorized/harmful autonomous actions	Unauthorized invocation, scope violation, guardrail bypass